Palacan

Architettura di Sicurezza

Documento tecnico · versione 1.2 · 2026

Abstract

Questo documento descrive l'architettura di sicurezza di Palacan: i principi di progettazione, il modello di minaccia considerato, i protocolli crittografici impiegati, la gestione delle sessioni e degli accessi, e le scelte tecniche che garantiscono la riservatezza delle comunicazioni. È rivolto a chi vuole valutare la piattaforma da un punto di vista tecnico, prima ancora di affidarsi alle nostre dichiarazioni. La sicurezza descritta qui non è un elenco di funzionalità aggiunte: è la conseguenza diretta di come il sistema è stato progettato fin dall'inizio.

1. Principio di progettazione

Palacan adotta un'architettura client-first: ogni operazione crittografica sensibile — generazione delle chiavi, cifratura, decifratura — avviene esclusivamente sul dispositivo dell'utente. Il server non partecipa mai a queste operazioni: la sua responsabilità è instradare dati già cifrati, gestire l'autenticazione e sincronizzare i dispositivi autorizzati.

Questa separazione non è una policy interna che potrebbe cambiare: è una proprietà strutturale del sistema. Il server non può accedere al contenuto delle conversazioni perché non possiede, in nessun momento, le chiavi necessarie per farlo.

2. Modello di minaccia

Il modello di minaccia definisce esplicitamente cosa il sistema protegge e da chi:

Minaccia	Mitigazione
Compromissione del server	I messaggi sono già cifrati end-to-end; il server non possiede le chiavi necessarie per leggerli.
Accesso amministrativo abusivo	Architettura zero-access: la gestione del workspace è separata dall'accesso ai contenuti.
Intercettazione di rete	Tutto il traffico client-server è protetto da TLS/HTTPS, oltre alla cifratura end-to-end dei messaggi.
Compromissione di una chiave di sessione	Forward secrecy: le chiavi si evolvono a ogni messaggio, isolando l'impatto di una compromissione.
Furto di credenziali (password)	Le password non sono mai conservate in chiaro: solo come hash, con funzioni dedicate resistenti ad attacchi a forza bruta.
Sessione compromessa o dispositivo smarrito	Le sessioni sono revocabili singolarmente e immediatamente da qualsiasi dispositivo autorizzato dell'utente.

Restano fuori dal perimetro di questo modello la sicurezza fisica del dispositivo dell'utente (es. un dispositivo rubato e non protetto da PIN) e i metadati tecnici strettamente necessari all'instradamento dei messaggi (identificativo del dispositivo, timestamp di consegna), ridotti al minimo indispensabile.

3. Crittografia end-to-end: Olm e Megolm

3.1 Olm — conversazioni individuali

Le conversazioni uno-a-uno sono protette dal protocollo Olm, un'implementazione del Double Ratchet Algorithm. Lo scambio iniziale delle chiavi avviene tramite un handshake basato su curve ellittiche (Curve25519), che stabilisce un segreto condiviso senza mai trasmetterlo in chiaro sulla rete. Da questo segreto, ogni messaggio deriva una nuova chiave attraverso una catena unidirezionale (ratchet), garantendo forward secrecy: se una chiave di sessione venisse compromessa, i messaggi scambiati in precedenza restano protetti, perché le chiavi che li proteggevano non sono più derivabili da quella compromessa.

Il ratchet di Olm è a doppio senso: si evolve sia lato mittente sia lato destinatario a ogni messaggio scambiato, così che la compromissione di una chiave non comprometta l'intera conversazione, ma solo una finestra temporale molto ristretta.

3.2 Megolm — conversazioni di gruppo

Per i gruppi, dove un doppio ratchet per ogni coppia di partecipanti non sarebbe praticabile su larga scala, Palacan utilizza Megolm: ogni partecipante genera una chiave di sessione condivisa (session key) che viene distribuita in modo cifrato agli altri membri autorizzati tramite Olm. La chiave di gruppo si aggiorna periodicamente e, in particolare, ogni volta che un membro esce dal gruppo — impedendogli di decifrare messaggi futuri con la chiave precedente.

3.3 Primitive crittografiche

Olm e Megolm, in quanto protocolli standard, si basano su un insieme di primitive consolidate e sottoposte a revisione paritaria:

Funzione	Primitiva
Scambio di chiavi	Curve25519 (curva ellittica)
Cifratura dei messaggi	AES-256 in modalità CBC
Autenticazione dei messaggi	HMAC-SHA-256
Derivazione delle chiavi	HKDF

Palacan non implementa un sistema crittografico proprietario. La robustezza della protezione non dipende dal fatto che il funzionamento del sistema resti segreto: dipende dalla solidità, pubblicamente verificabile, di queste primitive e della loro composizione all'interno di Olm e Megolm.

4. Ciclo di vita delle chiavi

Le chiavi private vengono generate localmente al momento della creazione dell'account o dell'aggiunta di un nuovo dispositivo, e restano memorizzate esclusivamente in un'area protetta del dispositivo stesso. Non vengono mai trasmesse al server, in nessuna fase del loro ciclo di vita.

Per consentire il recupero dell'accesso da un nuovo dispositivo, l'utente può attivare un backup cifrato delle proprie chiavi, protetto da una passphrase personale scelta dall'utente stesso. La passphrase non viene mai inviata al server: se viene persa, il backup non è più recuperabile — né dall'utente, né da Palacan. È una conseguenza diretta del principio zero-access, non un limite del sistema di recupero.

5. Gestione delle sessioni e autenticazione

L'accesso all'account è protetto da un token di sessione (JWT) associato a un identificativo univoco (jti) per ciascuna sessione attiva. Questo permette di distinguere e gestire singolarmente ogni dispositivo connesso: un utente può revocare una sessione specifica — ad esempio quella di un dispositivo smarrito — senza dover disconnettere tutti gli altri.

Alla revoca, la sessione viene invalidata lato server: qualunque richiesta successiva che utilizzi quel token viene rifiutata, indipendentemente dalla sua scadenza originale. Le sessioni hanno comunque una scadenza temporale di default, per limitare l'esposizione anche in assenza di una revoca esplicita.

6. Recupero dell'account

Palacan non si appoggia a un servizio email per il recupero della password. Al posto di questo, l'utente riceve un codice di recupero monouso (nel formato `XXXX-XXXX-XXXX-XXXX`), generato al momento della creazione dell'account. Il codice non viene conservato in chiaro: sul server ne risiede esclusivamente l'hash, sullo stesso principio applicato alle password. Un codice di recupero è utilizzabile una sola volta: dopo l'uso, viene invalidato e l'utente deve generarne uno nuovo.

7. Governance e RBAC nel workspace

Per le organizzazioni, Palacan applica un sistema di ruoli e permessi (RBAC) che governa esclusivamente aspetti amministrativi all'interno del proprio workspace: gestione degli utenti, assegnazione dei ruoli, configurazione delle policy di sicurezza.

Ruolo	Ambito
Workspace Admin	Gestione di utenti, dispositivi, ruoli e configurazioni di sicurezza all'interno del proprio workspace.
Utente	Utilizzo delle conversazioni, dei gruppi e delle funzionalità del workspace.

Nessun ruolo, incluso quello con i privilegi più ampi all'interno del workspace, include l'accesso al contenuto delle conversazioni. Questa non è una restrizione applicata a livello di interfaccia: è impossibile a livello architetturale, poiché le chiavi private necessarie a decifrare i messaggi non transitano mai attraverso l'infrastruttura server, nemmeno in forma temporanea.

8. Gestione dei dispositivi

Ogni dispositivo autorizzato da un utente rappresenta un'entità crittografica indipendente, con proprie chiavi di sessione. L'aggiunta di un nuovo dispositivo richiede una verifica esplicita, dopo la quale il nuovo dispositivo riceve le chiavi di sessione necessarie in forma cifrata. Un dispositivo smarrito, rubato o non più utilizzato può essere revocato in qualsiasi momento dalle impostazioni dell'account, impedendogli l'accesso a future comunicazioni — coerentemente con quanto descritto nella sezione 5 sulla gestione delle sessioni.

9. Protezione estesa oltre i messaggi

Il modello di cifratura end-to-end di Palacan non è limitato ai messaggi di testo. Si estende anche agli strumenti collaborativi integrati nella piattaforma per l'uso aziendale, come la gestione di attività condivise all'interno di una conversazione: anche in questi casi il contenuto resta leggibile esclusivamente dai partecipanti autorizzati, secondo lo stesso principio zero-access descritto in questo documento — non esiste un canale collaterale non cifrato per nessun tipo di contenuto scambiato sulla piattaforma.

10. Sicurezza dell'infrastruttura

- Tutto il traffico tra client e server è protetto da HTTPS/TLS, indipendentemente dal fatto che il contenuto sia già cifrato end-to-end.
- Le sessioni utente sono gestite tramite token con scadenza e possono essere revocate immediatamente da qualsiasi dispositivo

autorizzato (sezione 5).

- Le password sono conservate esclusivamente come hash tramite bcrypt, mai in forma leggibile, così che una compromissione del database non esponga le credenziali degli utenti.
- Le componenti software e le dipendenze del progetto sono monitorate e aggiornate con regolarità per ridurre l'esposizione a vulnerabilità note.

11. Conclusione

La sicurezza descritta in questo documento non è un traguardo raggiunto una volta per tutte: è un impegno che si rinnova a ogni versione della piattaforma, man mano che nuove minacce emergono e nuove pratiche di sicurezza si affermano. Questo documento verrà aggiornato di pari passo con l'evoluzione dell'architettura.

© 2026 Palacan · Documento tecnico, versione 1.2